SEMANA 9 · UNIDAD 2 · SEGURIDAD EN REDES

Monitoreo y logging de red: SIEM, IDS/IPS avanzado

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 9 · Periodo 2026-2 · Barranquilla, Colombia

PARTE 1 DE 4 · FUENTES DE EVIDENCIA

Qué registrar | Syslog | NetFlow/IPFIX | PCAP y NTP

MAPA

De dónde venimos y qué veremos esta semana

Cuatro bloques: evidencia, SIEM, IDS avanzado y la práctica en OPNsense.

SEMANA 9 · Monitoreo y logging de red: SIEM, IDS/IPS avanzado

De la bitácora suelta a la alerta que un analista puede defender

Parte 1 · Fuentes de evidencia

qué registrar · syslog
NetFlow · PCAP · NTP

salida: política de registro

Parte 2 · SIEM y correlación

ingesta y normalización
reglas · alertas · ATT&CK

salida: alerta con contexto

Parte 3 · IDS avanzado y NDR

Suricata · Zeek · reglas
DNS y beaconing

salida: detección afinada

Parte 4 · SOC, caso y práctica

ColCERT · IFX 2023
flujo de incidente

salida: laboratorio cerrado

Hilo conductor de la semana

Todo lo que se explica termina en una práctica sobre VirtualBox con OPNsense y Alpine:
Suricata generando alertas y syslog llevándolas a un colector dentro de la red del laboratorio.

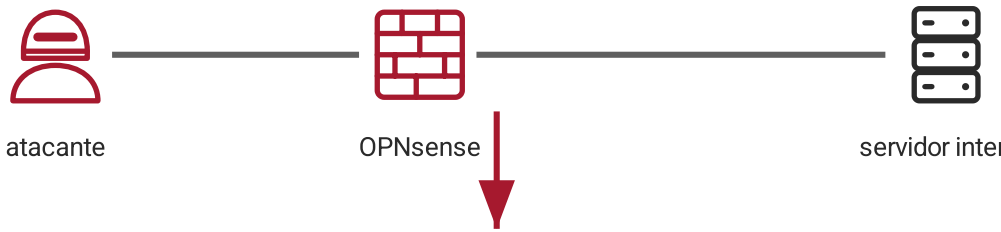
Diagrama propio · plan de la semana: docs/analisis-tematico.md §2.4

POR QUÉ

Sin bitácora, una intrusión no se puede probar

La misma visita con y sin registro: una deja rastro, la otra no.

Con bitácora: la secuencia se reconstruye



08:14:02 40 intentos SSH fallidos

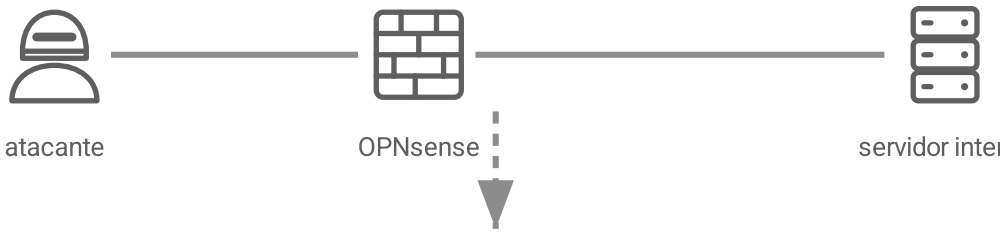
08:15:11 sesión abierta con respaldo

08:16:40 1,2 GB enviados hacia afuera

Hora, origen y acción: los tres hechos

con ellos se arma la línea de tiempo del incidente

Sin bitácora: nada que probar



sin hora registrada

?

sin origen identificable

sin acción que comparar

Sin cadena de custodia no hay prueba

la denuncia se estanca y la causa sigue ahí

Diagrama propio · concepto: NIST SP 800-92 (2006), §2.1 · Ley 1273 de 2009

TOPOLOGÍA

Cada zona genera eventos que convergen en un colector

OPNsense, servidores y estaciones envían syslog a un solo punto de la red.



Error clásico

cada equipo guarda sus logs
locales y nadie los revisa
al llenarse, se borran solos

COLECTOR · Alpine con rsyslog

udp o tcp 514, con una cola por origen
si el disco se llena, se pierden los más viejos
un archivo por dispositivo: opnsense.log

Almacenamiento

archivos diarios con rotación
retención y búsqueda por día
respaldo fuera de la red local

Regla de oro: quien decide en la red, también registra.

Y el colector avisa si un origen deja de hablar: un silencio prolongado también es un evento.

Diagrama propio · concepto: NIST SP 800-92 (2006), §2.3 · rsyslogd(8)

FORMATO

Una trama syslog: la prioridad viaja delante del texto

Anatomía del formato 5424: prioridad, hora con huso, host y mensaje.

PRI	VERSIÓN	TIMESTAMP	HOSTNAME	APP-NAME	PROCID	MSGID	STRUCTURED-DATA	MENSAJE
<165>	1	2026-10-04T08:14:02-05:00	opnsense-lab	suricata	1234	IDSDROP	[Origin ip="10.10.10.55"]	escaneo bloqueado

Prioridad = facility por 8 + nivel

165 = 20 por 8 más 5: local4.aviso

el nivel decide quién recibe la alerta

La hora trae su huso

-05:00 es la hora del emisor

el receptor la convierte a su zona

Dato estructurado, clave y valor

si no hay datos, se escribe un guion

ahí caben la IP de origen y la regla

El mensaje final es texto libre; para correlacionar, lo útil está en los campos que vienen antes.

Versión 1: RFC 5424, marzo de 2009. Transporte por TLS en RFC 5425 y por UDP en RFC 5426.

Si el hostname no corresponde al equipo real, la trama es válida pero la atribución falla.

NIVELES

Ocho severidades: de la emergencia a la depuración

La prioridad combina facility y nivel, y decide a quién despierta.

Nivel de severidad, del 0 al 7

0	1	2	3	4	5	6	7
emergencia	**alerta**	**crítica**	**error**	**aviso**	**notificación**	**información**	**depuración**
el sensor dejó de reportar	enlace crítico caído	ola de accesos fallidos	el servicio no responde	regla IDS revisada	usuario nuevo creado	sesión abierta con éxito	paquete examinado

Acción inmediata: alertar al turno — **Revisar en horario hábil** — **Solo afinar reglas**

El facility dice quién habla; el nivel dice qué tan grave es.

En el colector se filtra por los dos: <165> entra en la cola de avisos, <128> en la de emergencias.

Los ocho niveles vienen de BSD syslog; la RFC 5424 los conserva sin cambiar el orden.

Tres caminos del emisor al colector: UDP, TCP y TLS

Mismo mensaje, distinta garantía de entrega, cifrado y confirmación.

UDP · puerto 514



un datagrama por evento, sin acuse

- Mejor esfuerzo: si la cola del destino está llena, el mensaje se pierde.
- Soporta picos grandes sin frenar al emisor.

Sirve: volumen alto, pérdida tolerable

TCP · 514 o 601



conexión persistente con acuse

- El emisor reenvía lo que no fue confirmado; nada se pierde en silencio.
- Si el colector cae, la cola crece en el emisor y puede bloquearlo.

Sirve: evidencia que no puede perderse

TLS · puerto 6514



TCP además, con certificado X.509

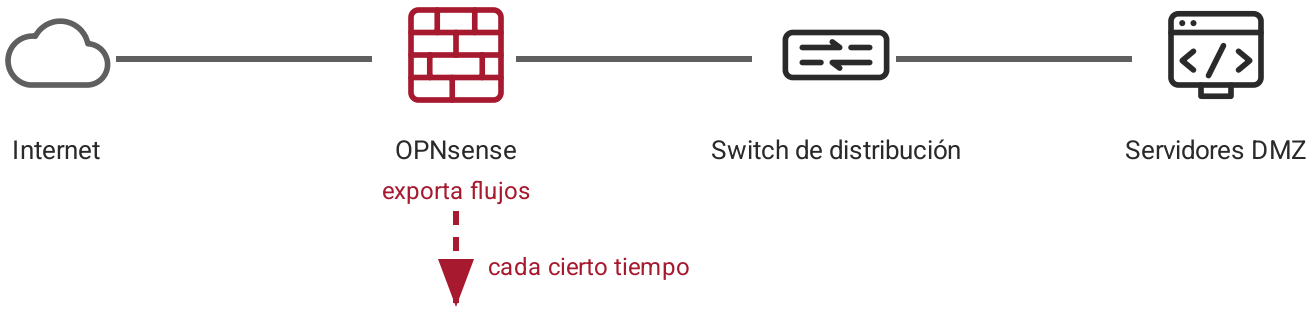
- Cifra el contenido en la red: nadie lee ni altera las bitácoras en tránsito.
- Exige confiar en la autoridad de certificados de ambos lados.

Sirve: tráfico que cruza redes ajenas

IETF RFC 5425 (2009) TLS · RFC 5426 (2009) UDP · RFC 6587 (2012) TCP

NetFlow resume la conversación en un registro por flujo

Cinco tupla más octetos: quién habló con quién, cuánto y cuándo.



Registro de flujo · 8 campos

1 IP de origen
2 IP de destino
3 puerto de origen
4 puerto de destino
5 protocolo
6 octetos enviados
7 paquetes contados
8 inicio y fin del flujo

UDP 2055

Colector de flujos

Retención corta: minutos u horas de conversaciones.

No guarda el contenido, guarda contadores y sentidos.

Responde rápido: ¿con quién habló este host esta noche?

Volumen anómalo, escaneos y destinos raros a simple vista.

El log dice qué pasó; el flujo dice cuánto y con quién.

NetFlow v9, RFC 3954 de 2004; IPFIX, el estándar que lo sustituye, RFC 7011 de 2013.

La captura de paquetes guarda el payload tal cual cayó

Tap, filtro y longitud de corte: la prueba que ningún log reemplaza.



Qué se elige en cada paso, y qué se arriesga

Sin filtro, el disco se llena en minutos. Con corte muy corto, se pierde la carga útil. Con espejo mal configurado, faltan tramas.

Única fuente que conserva el payload exacto

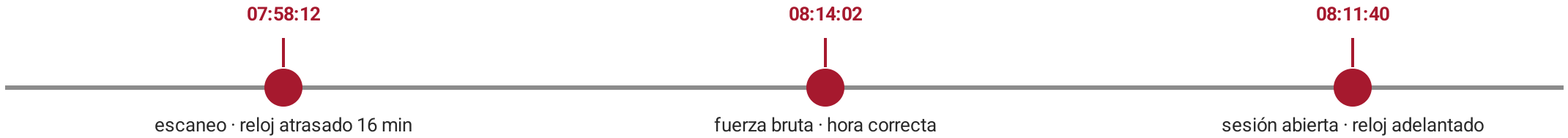
Los diccionarios de flujo y los logs describen; el .pcap demuestra byte a byte lo que circuló.

Diagrama propio · concepto: tcpdump(1) · capture filters de Wireshark

Sin relojes sincronizados, la correlación se rompe

NTP alinea a todos los dispositivos antes de que alguien investigue.

SIN NTP: tres relojes, tres verdades



Ordenadas por hora, la sesión parece anterior al ataque: la evidencia se contradice

CON NTP: la misma referencia para todos



Antes de abrir la bitácora: verificar NTP en OPNsense, en el colector y en los servidores

IETF RFC 5905 (2010) NTPv4 · Diagrama propio

ENTREGA

Tres formas de entregar el evento, una sola cola detrás

Agente, envío syslog o consulta por API: todo converge antes de guardar.

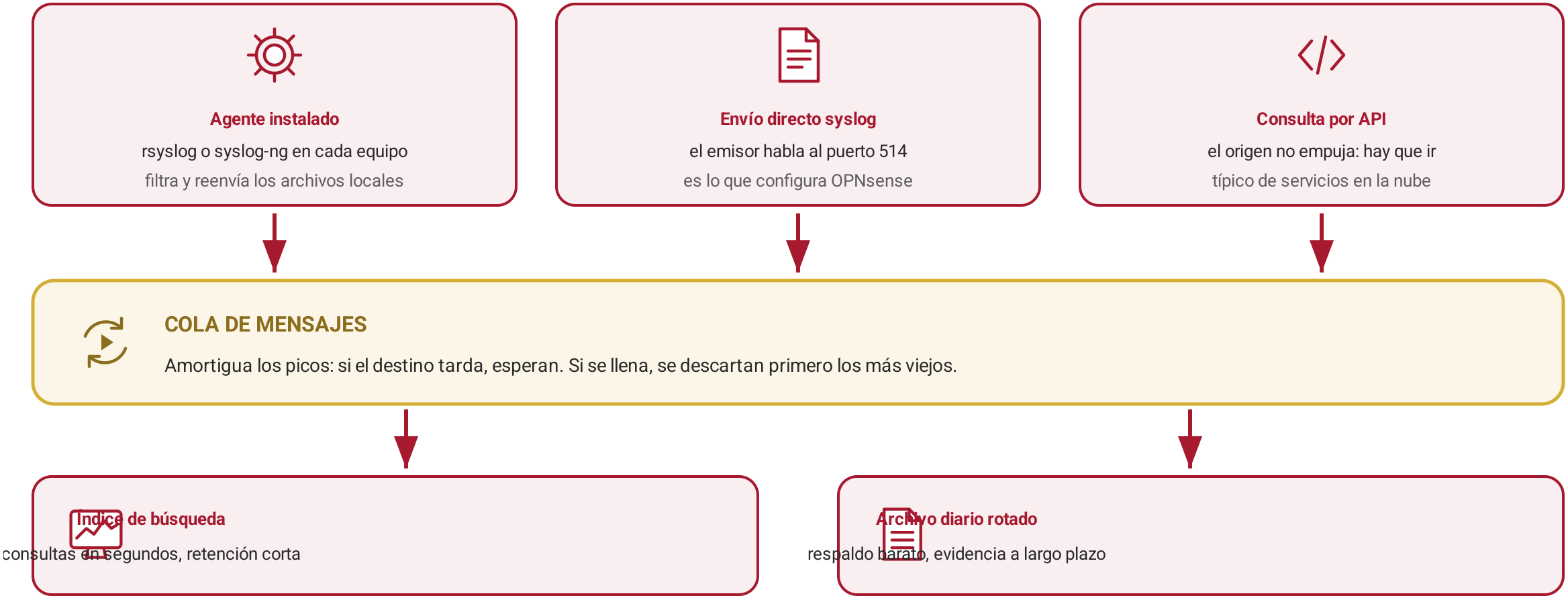


Diagrama propio · concepto: NIST SP 800-92 (2006), §2.3 · rsyslogd(8)

La retención se diseña: caliente, frío, archivo y legal

Cuatro niveles con distinta velocidad de búsqueda y distinto costo.



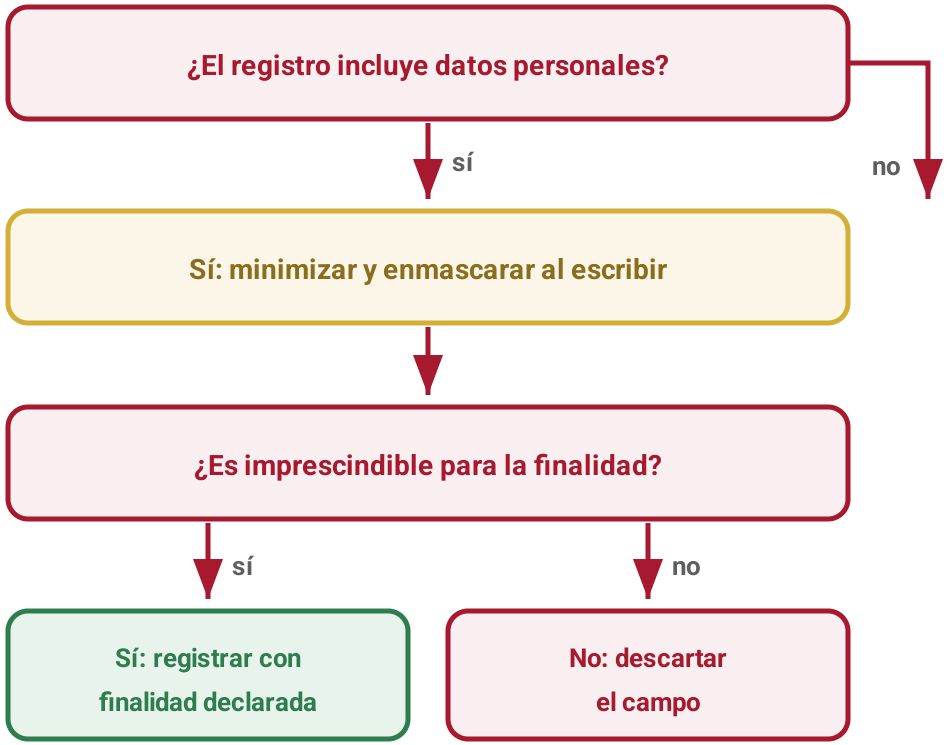
La retención se decide antes del incidente, no después.

En el laboratorio: rotación diaria y treinta días de consulta en el colector.

Diagrama propio · concepto: NIST SP 800-92 (2006), §4.1 retención

Registrar sin violar la Ley 1581 de 2012

Antes de guardar, pregunte si el dato es personal y para qué lo necesita.



No: guardar según la política de retención

Nunca en claro en una bitácora de red

- Contraseñas, claves de acceso y tokens de sesión.
- Números de tarjeta y datos de pago.
- Contenido de correos o mensajes privados.

Nuestro oficio registra equipos, puertos y acciones; el dato personal se trata aparte.

Congreso de Colombia, Ley 1581 de 2012, artículos 4, 9 y 15 · Anexo decreto 1377 de 2013

Cuando no llegan eventos, el diagnóstico es lineal

Generación, envío, recepción, disco y hora: un orden que no falla.

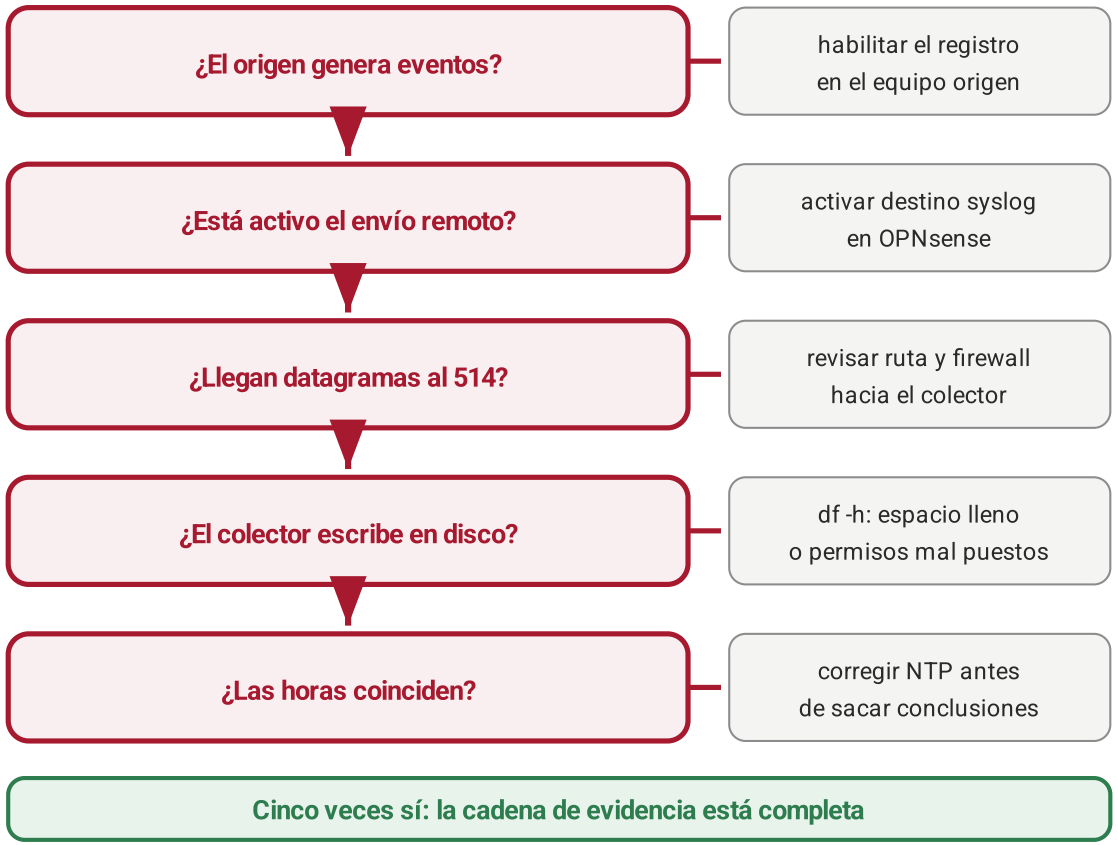
```
# 1 · ¿llegan datagramas al puerto 514?
tcpdump -ni eth0 udp port 514 -c 5

# 2 · ¿el colector escribe su archivo?
tail -f /var/log/opnsense.log

# 3 · ¿queda espacio en el disco?
df -h /var/log

# 4 · ¿coincide la hora con el emisor?
date -u
# con chrony: chronyc tracking
```

Orden: cada paso asume que el anterior ya fue verificado; no empiece por el final.



tcpdump(1) · df(1) · date(1) · Diagrama propio

SÍNTESIS

Lo que queda de la Parte 1

Evidencia que llega, a tiempo, completa y con permiso para existir.

La cadena de evidencia que sostiene la Parte 2



Si un eslabón falla, la alerta posterior no se sostiene.

Registros incompletos, horas falsas o discos llenos convierten un incidente en una disculpa.

Siguiente: el SIEM que recibe todo esto

Parte 2: ingesta, normalización, correlación y alertas con ATT&CK.

Diagrama propio · síntesis de la Parte 1

PARTE 2 DE 4

2

SIEM y correlación

Semana 9 · Monitoreo y logging de red: SIEM, IDS/IPS avanzado

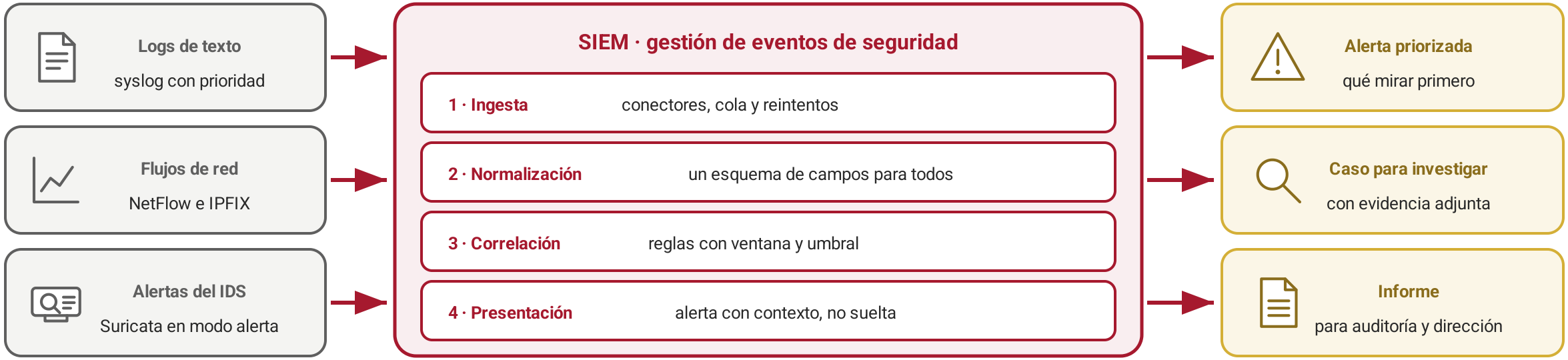
Ingesta y normalización | Correlación | Casos de uso | ATT&CK

CUC UNIVERSIDAD DE LA COSTA

MAPA

De la evidencia a la decisión en cuatro saltos

La Parte 2 sigue el evento desde que entra al SIEM hasta que alguien actúa.



Parte 2 · cuatro paradas

1 · Cómo entran los eventos y cómo se normalizan

2 · Cómo se guardan para poder buscarlos

3 · Cómo una regla convierte eventos en alerta

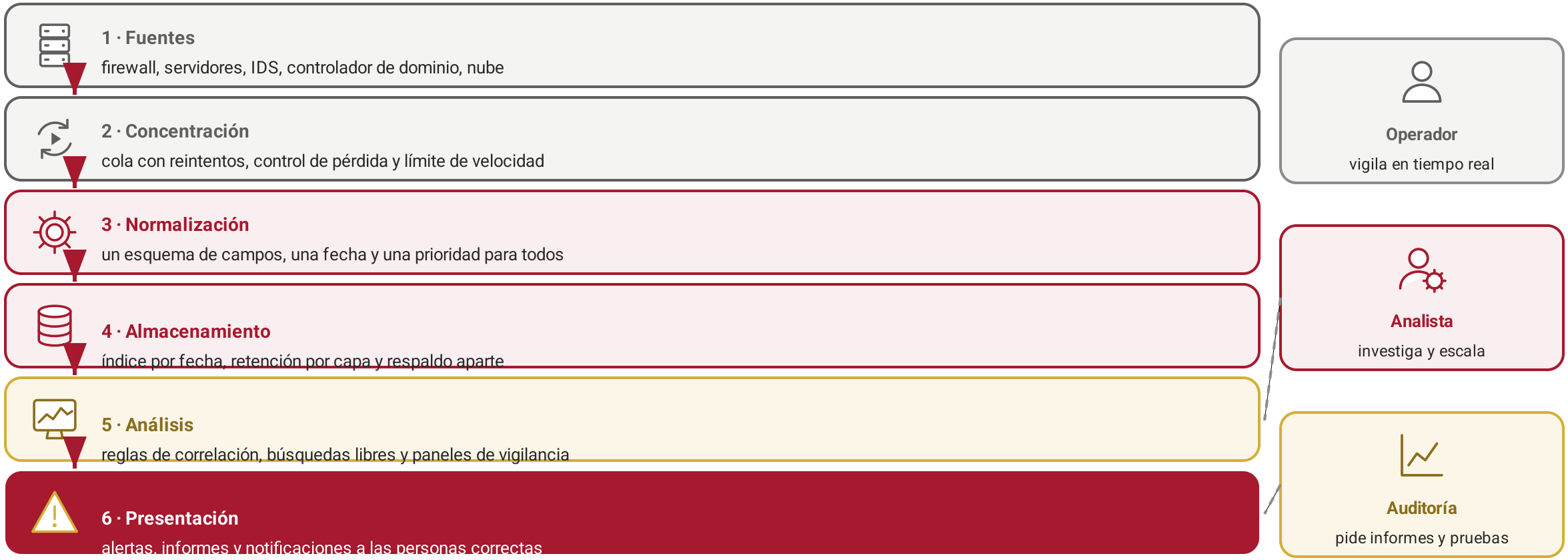
4 · Cómo se mide y se reduce el tiempo de respuesta

Diagrama propio · concepto: NIST SP 800-92 (2006), §3.1

ARQUITECTURA

El SIEM es una cadena de seis capas

De la fuente al informe: cada capa falla por separado y se repara por separado.



Ingesta: identificar el formato antes de extraer

Un mismo puerto 514 recibe tramas de cinco productos distintos.

```
<165>1 2026-10-04T08:14:02-05:00 opnsense-lab suricata 1234 IDSDROP [Origin ip="10.10.10.55"] escaneo bloqueado
```

1 · Identificar

hostname y app-name dicen de qué producto viene la trama

2 · Extraer

patrón con expresiones regulares que separan cada campo del texto

3 · Convertir

texto a número, fecha y dirección IP válida para poder ordenar

4 · Limpiar

descartar latidos y depuración antes de gastar índice

Campos que salen del parseo y alimentan todas las reglas

- event.time
- host.name
- log.level
- source.ip
- rule.id
- event.action

Si el patrón falla, el evento entra como no parseado

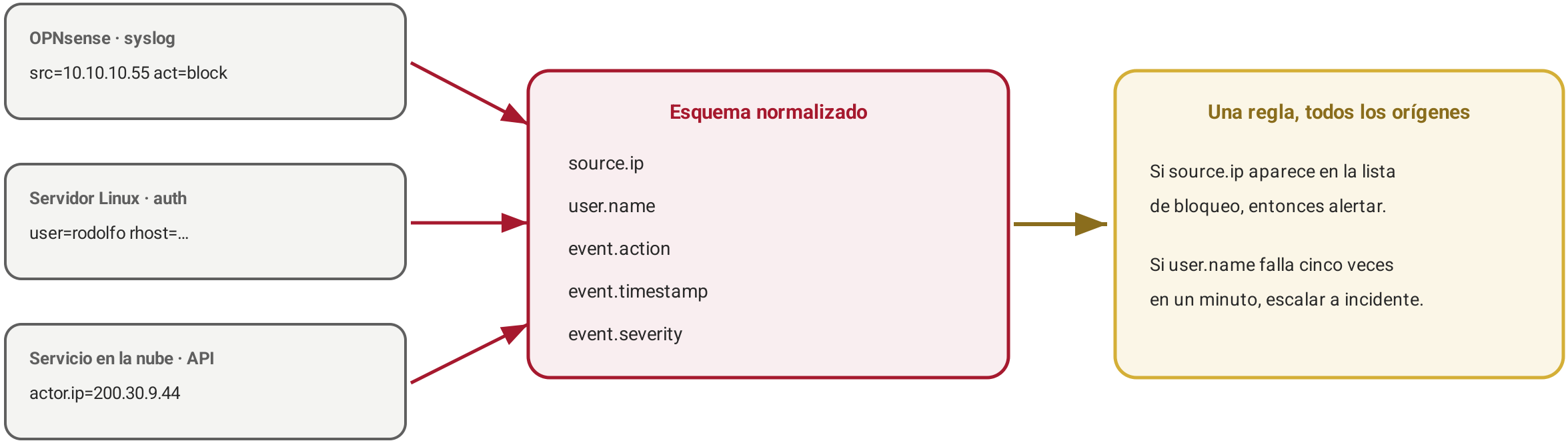
Sigue ocupando espacio y tiempo, pero no participa en ninguna regla: es el fallo silencioso más común de la ingesta.

Control: cuente los eventos sin parsear por origen; si crecen, alguien cambió el formato del producto y nadie avisó.

Diagrama propio · concepto: NIST SP 800-92 (2006), §3.2 ingesta de registros

Tres dialectos, un solo esquema de campos

La regla escribe una sola vez y funciona con todos los productos.



Esquemas abiertos como ECS u OCSF: elijo uno y documento cada equivalencia.

Diagrama propio · esquemas abiertos: Elastic Common Schema (2018–) · OCSF (2023–)

El índice se parte por día y se apaga por capa

Lo reciente se busca al instante; lo viejo se retira entero, sin tocar el resto.

Índice invertido: de la palabra al documento

source.ip=10.10.10.55	documento 4821, 4907, 5010
user.name=rodolfo	documento 4788, 5120
event.action=fallo	documento 4788, 4907, 5120
host.name=opnsense-lab	todos los documentos de hoy

Particiones por día, retención por capa

04 oct · reciente

índice completo, búsqueda instantánea, disco rápido

27 sep a 03 oct · caliente

mismo índice, disco de mayor capacidad

meses anteriores · frío

archivo comprimido, se consulta bajo solicitud

Borrar por partición completa: nunca fila por fila

Retirar un día entero no fragmenta el índice ni obliga a reescribir lo que sigue vivo.

Costo visible: el índice ocupa más que el archivo original porque además guarda la estructura de búsqueda.

Diagrama propio · concepto: NIST SP 800-92 (2006), §4.1 retención y §4.2

Una regla es condición, ventana y umbral

Cinco fallos de acceso en sesenta segundos no son cinco alertas, sino un patrón.

Condición
autenticación fallida

→

Ventana
sesenta segundos móviles

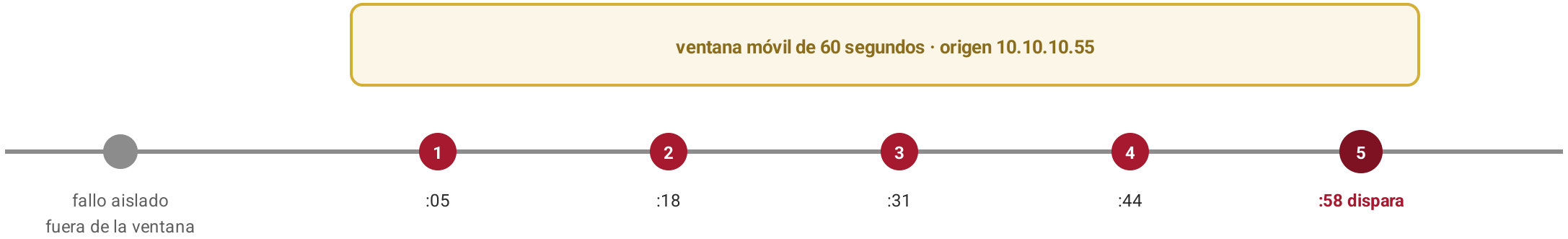
→

Umbral
cinco o más del mismo origen

→

Alerta única
con la lista de eventos

La misma regla, en línea de tiempo



Agrupar
un solo aviso por origen, no diez avisos sueltos

Suprimir
repetir la misma alerta cada cinco minutos mientras siga el patrón

Enriquecer
añadir activo crítico, usuario y geografía antes de notificar

Diagrama propio · concepto: correlación de eventos, NIST SP 800-92 (2006), §3.3

SECUENCIA

Del evento a la alerta en pantalla, paso a paso

Cuatro actores y un orden estricto: si uno se cae, la alerta no aparece.

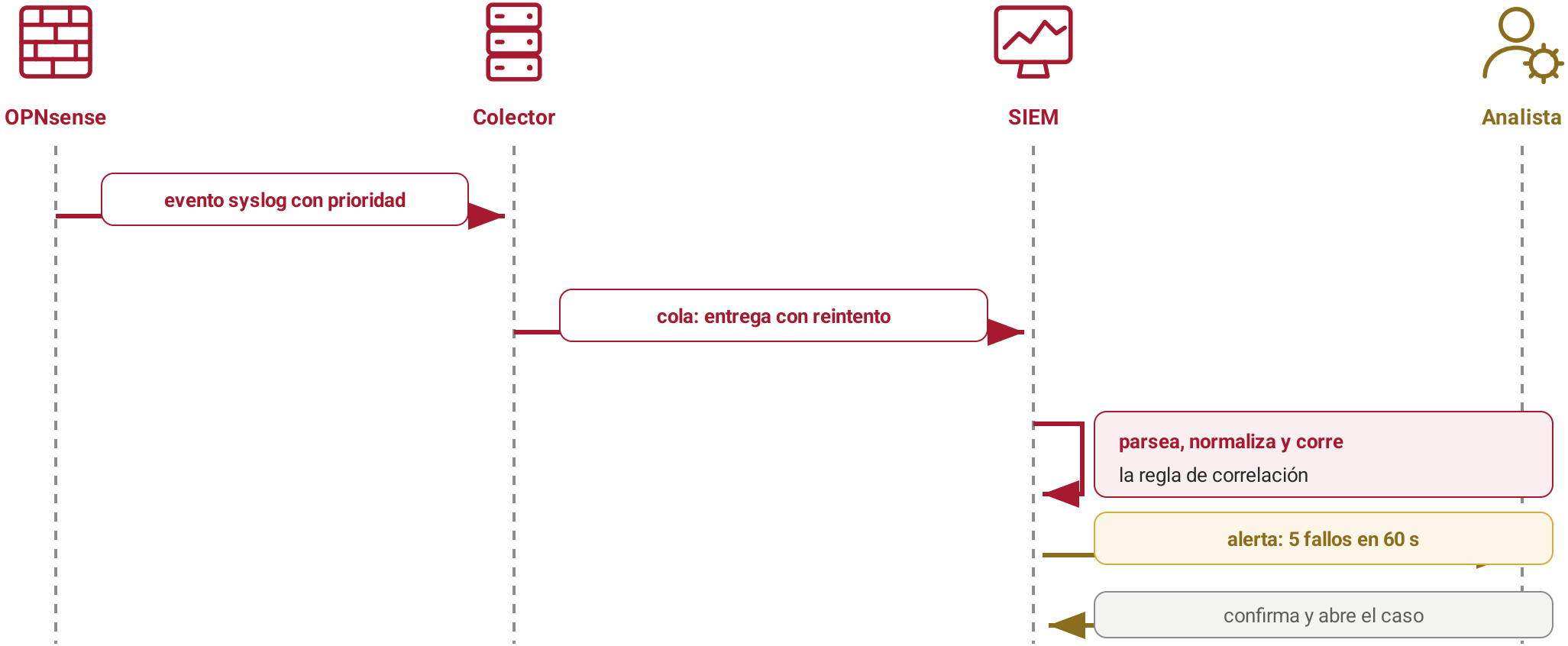
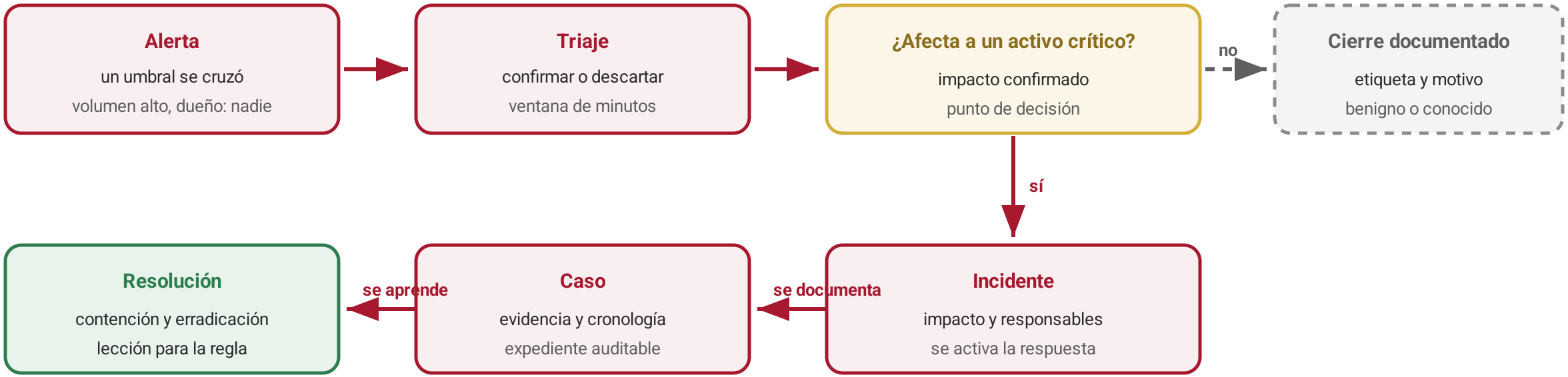


Diagrama propio · concepto: NIST SP 800-92 (2006), §3.1 flujo de eventos

Alerta, incidente y caso: tres cosas distintas

Cambia el volumen, el responsable y la exigencia de evidencia.



Toda alerta termina en un estado explícito: ninguna queda abierta por costumbre.

Los cierres se etiquetan, porque mañana alimentan la supresión y la afinación de las reglas.

El caso conserva la evidencia que la Parte 1 aprendió a recolectar: logs, flujos y capturas.

Diagrama propio · concepto: NIST SP 800-61 Rev.3 (2025), gestión de incidentes

El embudo: de miles de eventos a una decisión

El valor no está en generar alertas, sino en reducirlas a lo accionable.



Las anchuras son ilustrativas: la relación real depende del volumen y de cuántas reglas están afinadas.

Suprimir

Lo conocido y benigno deja de repentarse cada cinco minutos.

Agrupar

Los duplicados por origen y por regla se convierten en uno solo.

Priorizar

El activo crítico sube al toque del embudo, el resto espera.

Diagrama propio · el embudo es una idea de diseño; las proporciones son ilustrativas

El atacante avanza por tácticas, ustedes vigilan cada paso

La cadena de tácticas traduce el ataque en puntos concretos de detección.

Acceso inicial	Credenciales	Descubrimiento	Movimiento lateral	Comando y control	Exfiltración
T1078 cuentas válidas	T1110 fuerza bruta	T1046 sondeo	T1021 servicios remotos	T1071 · T1572 túnel	T1041 salida por C2
Lo que ve el SIEM					
sesión válida inesperada	cuarenta fallos por origen	barrido de puertos	SSH entre zonas nuevas	salida en hora rara	volumen alto hacia afuera

El marco ATT&CK es vocabulario, no producto

Agrupa las tácticas del atacante en categorías estables y les da un código común para hablar con otros equipos.
Ese código es el que aparece en las alertas y en los informes de cualquier fabricante.

Regla práctica: por cada táctica de su cadena, al menos una regla activa.

Si una táctica no tiene detección, es exactamente por donde entrará alguien sin que nadie lo note.

MITRE ATT&CK® Enterprise, técnicas T1078, T1110, T1046, T1021, T1071, T1572, T1041 (consultado 2026)

Medir el tiempo: detectar rápido y contener más rápido

Dos relojes y varios frenos: dónde se pierde el tiempo en cada tramo.



Freno de detección
fuente que no registraba
o reloj desincronizado

Freno de análisis
cola sin vigilar y
reglas ruidosas

Freno de decisión
contacto sin definir y
procedimiento que nadie escribió

Freno de recuperación
cambio sin ventana y lección
que no vuelve a la regla

Baja el MTTD

Todas las fuentes hablando, cola vigilada,
reglas probadas con eventos de prueba.

Baja el MTTR

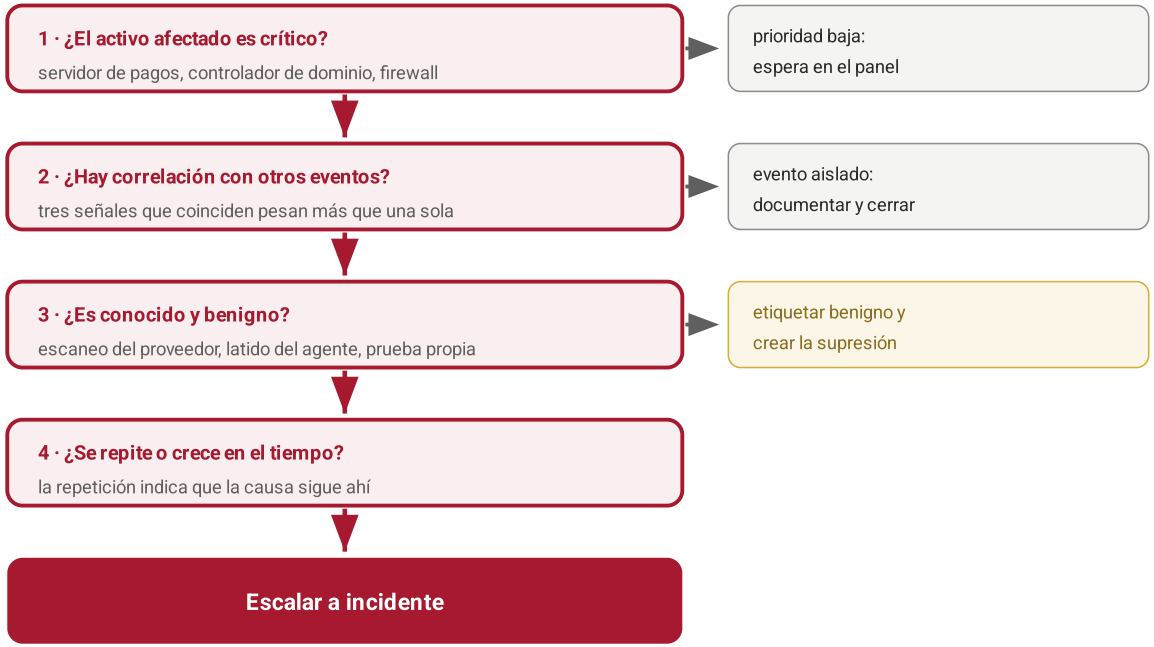
Procedimiento escrito, contactos acordados
y ventana de cambios lista para usarse.

Diagrama propio · concepto: métricas de detección y respuesta, NIST SP 800-61 Rev.3 (2025)

TRIAJE

Cuatro preguntas antes de escalar una alerta

El triaje rápido separa el ruido del evento que sí cambia el riesgo.



Qué debe llevar la alerta al triaje

- El activo afectado y su criticidad.
- Origen y destino, ya normalizados.
- Hora verificada con la referencia NTP.
- La regla que disparó y su umbral.
- Evidencia adjunta: trama o captura.

Etiquetas que alimentan la afinación

falso positivo · benigno conocido · escaneo propio · incidente

Cada etiqueta de hoy es una supresión o una mejora de mañana.

Diagrama propio · concepto: triaje de alertas, NIST SP 800-61 Rev.3 (2025), §3.2

PRUEBA

Sin prueba, el monitoreo es una suposición

Inyecte un evento, siga su rastro y cierre la brecha que encuentre.

1 · Inyectar

logger -p local4.info "prueba-s09"

evento sintético, marcado y reconocible

2 · Verificar llegada

tcpdump -ni eth0 udp port 514

el datagrama aparece en el colector

3 · Verificar parseo e índice

buscar prueba-s09 en el índice

si no aparece, el patrón falló

4 · Forzar la alerta

regla de prueba activa y notificación recibida

Matriz de cobertura: fuente por tipo de evento

	autenticación	error	cambio	IDS
OPNsense firewall e IDS		✓	✓	✓
Servidor Linux aplicación y sistema	✓	✓	✓	
Switch y red enlaces y vecinos		✓	✓	

Casilla vacía: brecha conocida

Alguien decide si se llena o se acepta por escrito.

Diagrama propio · concepto: pruebas de detección y matriz de cobertura

SÍNTESIS

Lo que queda de la Parte 2

Eventos que entran ordenados, reglas con ventana y métricas que se revisan.

La cadena del SIEM que sostiene la Parte 3



Ingesta

identificar, parsear y vigilar los fallos



Normalización

un esquema y una regla para todos



Almacenamiento

índice por día y retención por capa



Correlación

condición, ventana y umbral, luego triaje



Métricas

tiempo de detección y de resolución

Lo que no se prueba, se supone.

Prueben la cadena completa cada vez que cambien un componente.

Siguiente: detectar en el tráfico con Suricata y Zeek

Parte 3: reglas, salida estructurada, DNS, beaconing y afinamiento.

Diagrama propio · síntesis de la Parte 2

PARTE 3 DE 4

3

IDS/IPS avanzado y NDR

Semana 9 · Monitoreo y logging de red: SIEM, IDS/IPS avanzado

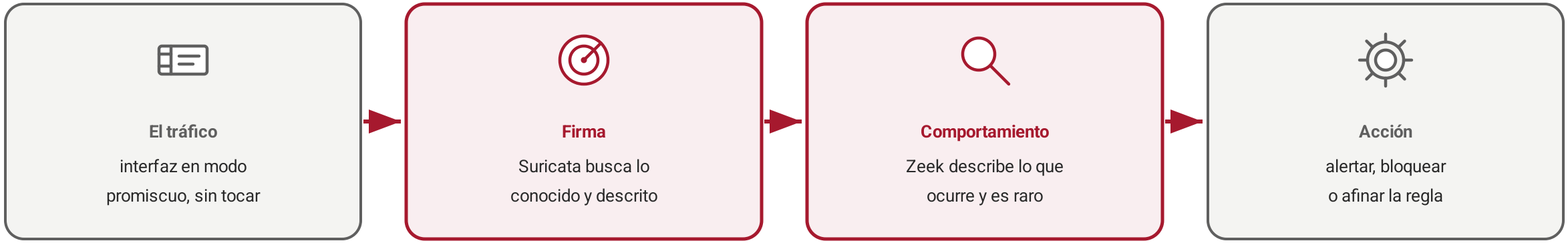
Suricata | Zeek | Afinamiento | DNS y beaconing

CUC UNIVERSIDAD DE LA COSTA

MAPA

Cuatro paradas para detectar en el tráfico

Suricata y Zeek miran el mismo enlace con dos preguntas distintas.



Todo lo que sale de aquí es evidencia para el SIEM

alertas de Suricata, logs de Zeek y contadores del propio sensor.

Pregunta de la parte: ¿qué hace alguien cuando nadie lo mira?

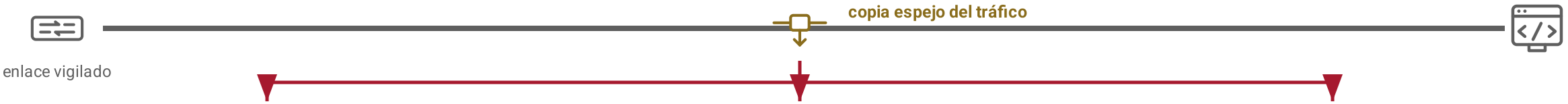
Firma para lo conocido, comportamiento para lo raro, ajuste para el ruido.

Diagrama propio · concepto: detección en tráfico, NIST SP 800-94 (2007)

COMPARACIÓN

Tres maneras de mirar el mismo enlace

Firma, comportamiento y análisis externo: se complementan, no compiten.



Suricata · firma

Pregunta: ¿qué busqué?

Compara contra reglas escritas por personas y firmas públicas.

Trabaja en modo detección o en modo de bloqueo en línea.

Escribe eventos estructurados por cada coincidencia.

Límite: solo sabe lo que se describió; cada firma nueva hay que escribirla.

Zeek · log

Pregunta: ¿qué pasó?

No lleva reglas: describe la conversación protocolo a protocolo.

Deja archivos planos con campos fijos por tipo de tráfico.

La detección la hace el SIEM o el analista después, no él.

Fortaleza: evidencia rica y sin reglas; el juicio llega después, con contexto.

Análisis de red

Pregunta: ¿qué es raro?

Aprende lo normal durante un periodo y marca las desviaciones.

Compara volumen, horario, destinos y frecuencia.

Puede ser producto comprado o proceso armado con código propio.

Fortaleza: cubre lo nunca visto; exige historia para comparar.

Ninguno reemplaza al firewall: el firewall aplica política y estos explican lo que la política no contempla.

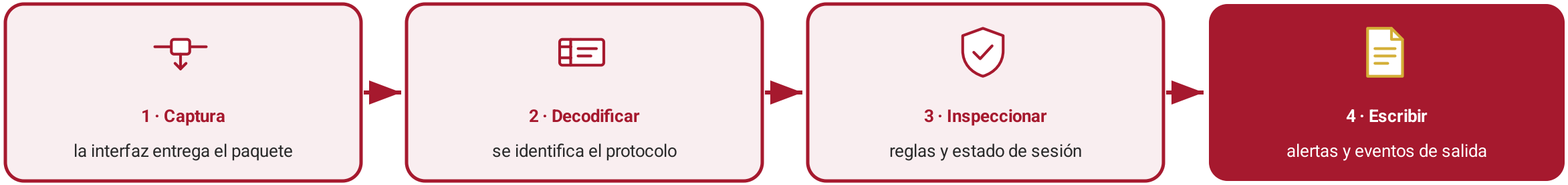
En el laboratorio corren Suricata y Zeek: son de código abierto y caben en VirtualBox.

Concepto: Suricata (OISF), Zeek, análisis de red (NIST SP 800-94, 2007)

PROCESO

Cómo Suricata procesa un paquete

Captura, decodifica, inspecciona y escribe: cuatro etapas con su pérdida posible.



Límite de la tarjeta
y del modo elegido

Paquete mal formado
queda sin clasificar

Memoria y CPU
siguen el estado de sesión

Cola saturada
eventos descartados

El sensor expone contadores de pérdida: revísenlos como revisan el disco

Si la cola de salida no absorbe a la misma velocidad, los eventos se descartan en silencio.

La detección perfecta no existe: existe la medición de lo que se pierde.

Concepto: motor de inspección Suricata, OISF; NIST SP 800-94 (2007), §4.3

Una regla: cabecera, mensaje y clasificación

La acción decide qué solo registra, qué bloquea y qué cierra la conexión.

```
alert http $HOME_NET any -> $EXTERNAL_NET any (
msg:"ET MALWARE beacon sospechoso";
sid:1000001; rev:1;
classtype:trojan-activity;)
```

acción + protocolo + dirección de tráfico + puertos

mensaje visible · identificador único · versión · tipo

alert

escribe el evento y continúa

drop

descarta el paquete en modo en línea

reject

bloquea y contesta con un cierre

Reglas públicas: el camino del conjunto abierto hasta la regla útil

1 · Descargar y revisar

el conjunto abierto, desde el panel

→

2 · Activar en modo alert

y observar una semana completa

→

3 · Apagar las ruidosas

y documentar el motivo

Un cambio por vuelta: si se mueven varias reglas a la vez, después nadie sabe cuál sirvió.

SALIDA

EVE: cada evento en una línea JSON

Un evento por línea permite enviarlo al colector sin escribir un patrón nuevo.

```
{"timestamp":"2026-10-04T10:15:00",
"event_type":"alert",
"src_ip":"10.20.30.15","src_port":51234,
"dest_ip":"200.30.12.9","dest_port":443,
"proto":"TCP",
"alert":{"signature":"ET SCAN puertos",
"severity":2,"action":"allowed"},
"payload":"... omitido ..."}
una línea = un evento completo, ordenado por hora
```

Suricata escribe
archivo de eventos, una entrada por línea

Agente o syslog lo reenvía
sin romper la estructura de cada línea

El colector lo recibe
el patrón de extracción es casi gratuito

Llega al índice
campos consultables desde el primer minuto

Si la última línea tiene horas de retraso, el proceso dejó de escribir

Vigilar la frescura del archivo es la forma más simple de monitorear al sensor.

Concepto: salida EVE JSON de Suricata, documentación oficial de OISF

EVIDENCIA

Zeek no alerta: describe lo que pasó

Cinco archivos de log bastan para reconstruir la conversación de una red.

archivo	campos principales	para qué sirve
conn.log conexiones	ts, orig_h, resp_h, proto, duration bytes de ida y vuelta, cierre de sesión	toda la conversación, base de cada consulta
dns.log dominios	query, qtype_name, answers, rcode nombre pedido y respuesta recibida	aquí primero aparece un túnel de dominios
http.log peticiones web	method, host, uri, status, user_agent sitio visitado y código de respuesta	descarga de archivos y navegación rara
ssl.log capa segura	server_name, version, ja3, notbefore certificado presentado y huella del cliente	sirve aunque el canal esté cifrado
notice.log avisos propios	note, msg, src, dst lo que Zeek consideró llamativo solo	punto de partida para una regla propia

Zeek deja los hechos; el juicio de si algo es malo lo hace el SIEM con la evidencia junta.

Concepto: archivos de log de Zeek, documentación oficial del proyecto

Matriz: severidad cruzada con frecuencia

La prioridad nace de cruzar qué tan grave es con qué tan seguido ocurre.

severidad	frecuencia baja	frecuencia media	frecuencia alta
ALTA activo crítico	**Investigar ya** un solo evento puede bastar	**Investigar hoy** entra en la cola de la jornada	**Incidente: escalar** impacto y repetición confirmados
MEDIA activo normal	**Observar** queda anotado para la revisión	**Ajustar el umbral** la regla se acerca a dispararse	**Suprimir o bloquear** acción según el impacto real
BAJA ruido esperado	**Archivar** queda el registro, no la acción	**Revisar en lote** una vez por semana basta	**Regla mal afinada** se revisa antes que el evento

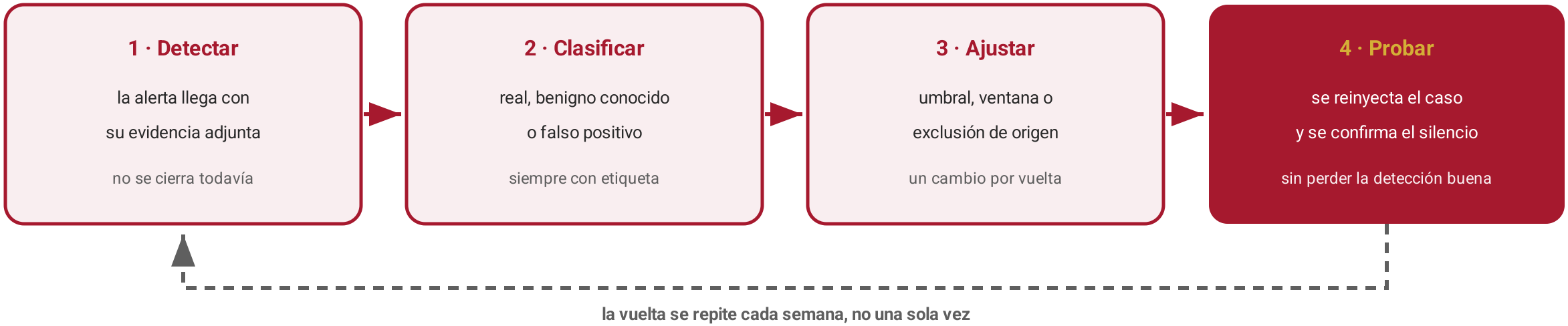
Ninguna celda dice ignorar: cambian el momento y el responsable.

La severidad la pone la regla y el activo; la frecuencia la pone la ventana de correlación.

Diagrama propio · concepto: priorización de alertas, NIST SP 800-61 Rev.3 (2025)

El ciclo que convierte ruido en regla útil

Detectar, clasificar, ajustar y probar: cada vuelta estrecha el embudo.



Cada vuelta queda escrita en el caso: qué se cambió, cuándo y por quién

· Si se cambian varias cosas a la vez, después nadie sabe cuál sirvió.

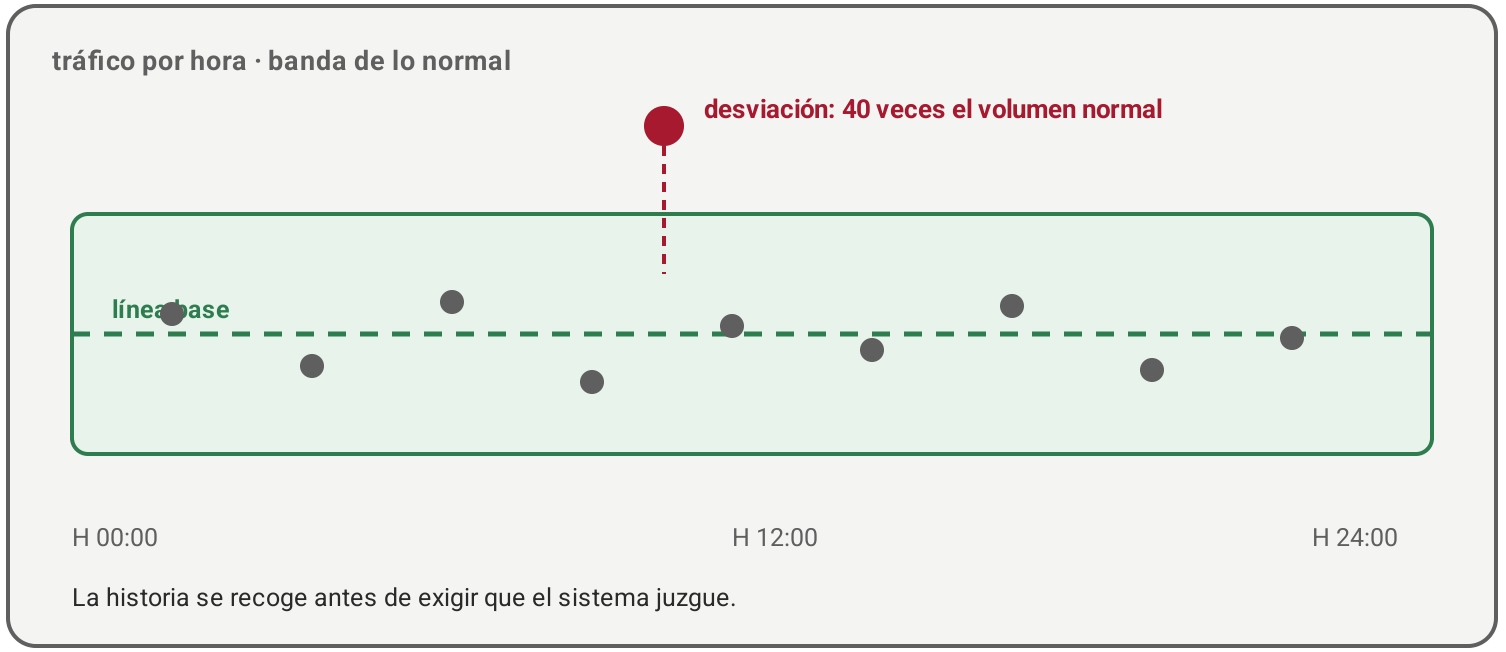
· Si se ajusta sin reinyectar el caso, la siguiente semana vuelve el ruido.

· Si nadie documentó el motivo, alguien revertirá el cambio sin avisar.

Diagrama propio · concepto: afinación continua de detección, NIST SP 800-94 (2007)

Anomalía: primero existe la línea base

Dos semanas de tráfico normal definen lo que después se considera raro.



La historia se recoge antes de exigir que el sistema juzgue.

Volumen

cuánto pasa respecto a lo habitual

Horario

en qué franja debería haber nada

Destino

a quién habla la organización por vez primera

Repetición

con qué regularidad vuelve a ocurrir

Sin línea base no hay anomalía; y la línea base se actualiza, no se congela

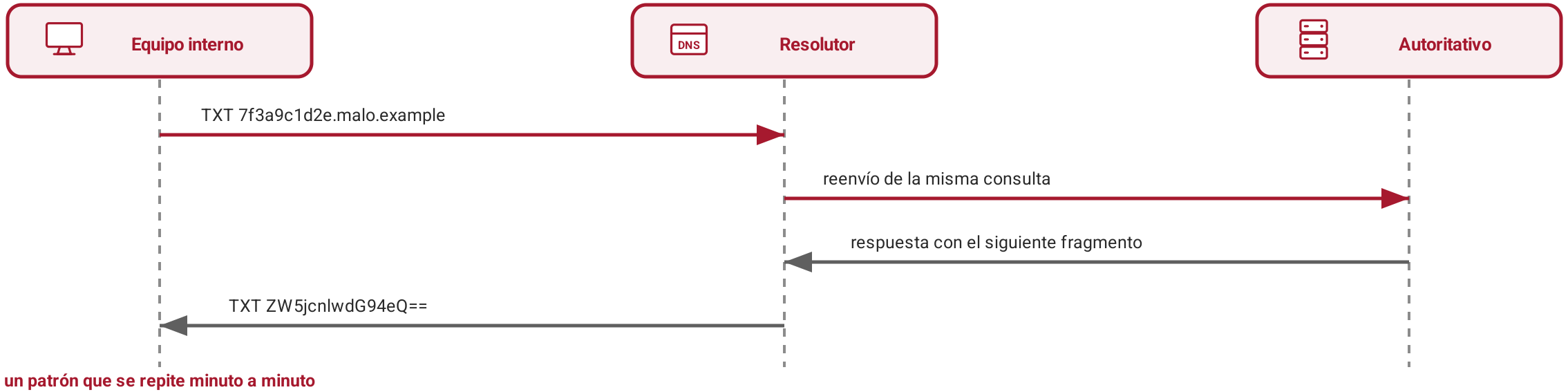
Si la red cambia y la referencia no, todo empieza a parecer raro y la alerta se vuelve rutina.

Diagrama propio · concepto: línea base y detección de anomalías, NIST SP 800-94 (2007)

CASO RARO

DNS tunneling: datos escondidos en consultas

Subdominios largos y aleatorios revelan un canal que no debería existir.



un patrón que se repite minuto a minuto

Indicador 1

subdominio largo y aleatorio

se ve completo en el log de dominios

Indicador 2

consultas de texto muy seguidas

contra el mismo servidor autoritativo

Indicador 3

volumen fuera del horario

la organización no consulta nada de noche

Concepto: túnel sobre consultas de dominio; Zeek dns.log; MITRE ATT&CK T1071.004

CASO RARO

Beaconing: el latido que delata el control

Intervalos casi fijos hacia el mismo destino, de día y también de noche.

sesiones hacia el mismo destino · hora por hora

Acceso humano: irregular



los huecos cambian: reunión, almuerzo, fin de semana.

Latido automatizado: casi perfecto



mismo tamaño de hueco todo el rato, también de madrugada.

Intervalo casi fijo

la desviación entre consultas es mínima: es un temporizador

Mismo destino

una sola dirección y un solo puerto, aunque cambie la hora

Continuo

no descansa en horario laboral ni en fines de semana

La señal no es una consulta: es la repetición ordenada en el tiempo

Se detecta ordenando el archivo de conexiones por destino y por hora, sin mirar el contenido.

VOCABULARIO

Del indicador a la técnica del atacante

Cada cosa rara que ven corresponde a un paso del marco de tácticas.

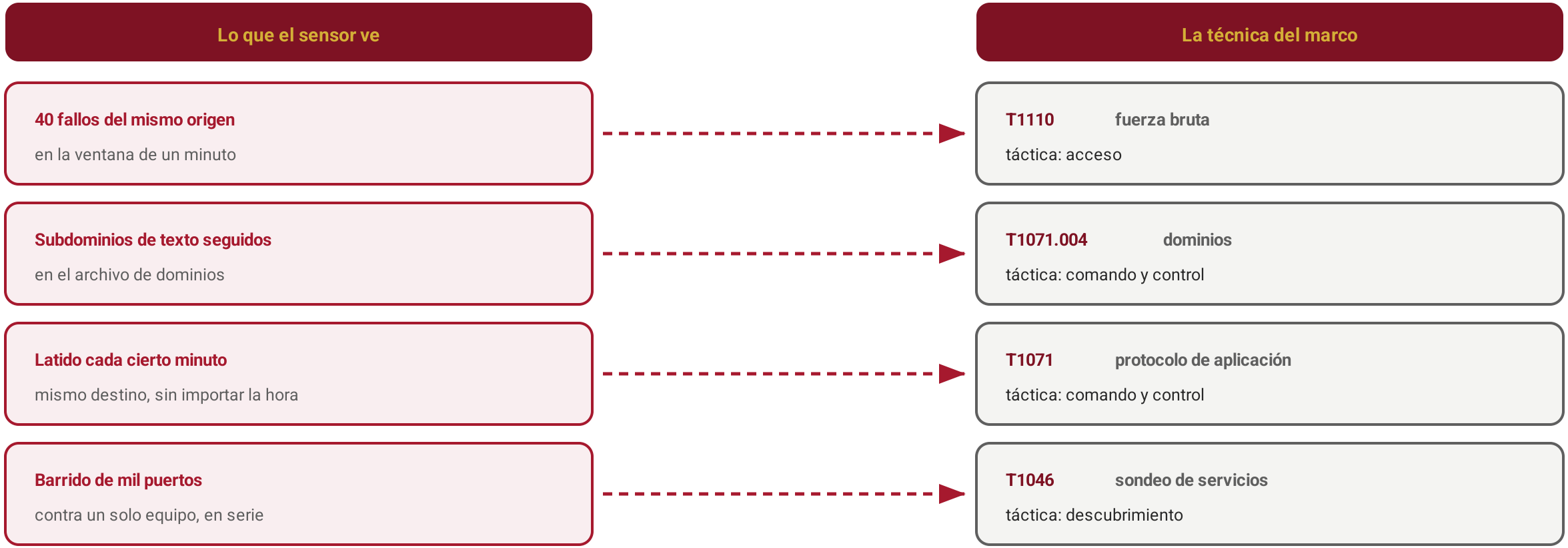


Diagrama propio · mapeo a MITRE ATT&CK Enterprise: T1110, T1071, T1071.004, T1046

El sensor también falla, y hay que mirarlo

Interfaz mal puesta, reglas viejas o proceso con retraso: deja de ver.

Chequeo semanal del sensor

- Interfaz escuchando en modo promiscuo.
- Reglas descargadas y sin fallos de lectura.
- Fecha de actualización reciente.
- Contadores de pérdida en cero.
- Hora sincronizada con la referencia.
- Última línea del archivo con hora corriente.

Interfaz equivocada

captura el tráfico de nadie y no
levanta ningún error en pantalla.

el modo más común al montar el laboratorio

Reglas sin actualizar

solo se buscan amenazas de hace
meses, y la detección se queda quieta.

se comprueba la fecha, no el botón

Proceso con retraso

las alertas llegan horas después
y la respuesta ya no alcanza.

se mide con la hora de la última línea

Concepto: operación y verificación de sensores, NIST SP 800-94 (2007), §5

SÍNTESIS

Lo que queda de la Parte 3

Firma para lo conocido, comportamiento para lo raro y ajuste continuo.

Del paquete a la regla afinada



Un sensor que no ve no protege: da tranquilidad falsa.

Por eso el chequeo semanal es parte de la detección, no un trámite aparte.

Siguiente: proceso, personas y la práctica en OPNsense

Parte 4: equipo de respuesta, marco colombiano, caso IFX y los cinco pasos del laboratorio.

Diagrama propio · síntesis de la Parte 3

PARTE 4 DE 4

4

SOC, caso colombiano y práctica

Semana 9 · Monitoreo y logging de red: SIEM, IDS/IPS avanzado

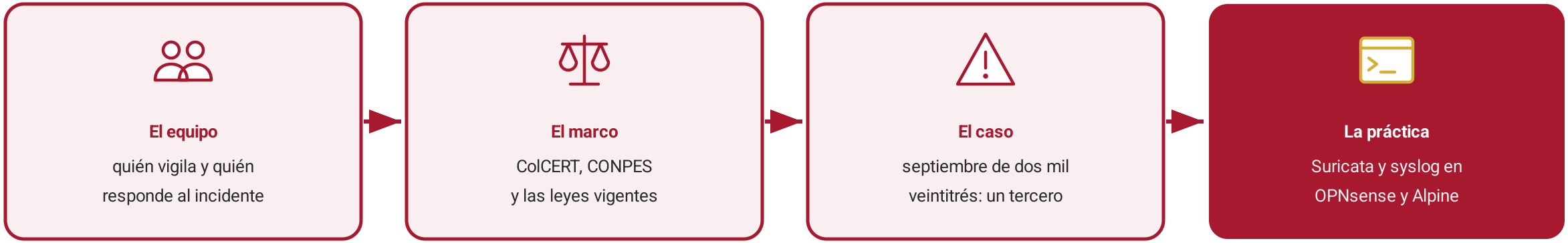
SOC y CSIRT | Auditoría en nube | ColCERT | Suricata + syslog

CUC UNIVERSIDAD DE LA COSTA

MAPA

De la alerta a la práctica guiada

Equipo, marco colombiano, caso real y los pasos para montarlo.



La parte cuatro siempre cierra con la práctica sobre la topología del laboratorio

cinco pasos, cada uno con su verificación; nada que instalar fuera de VirtualBox.

Y después: las fuentes consultadas y el puente a la semana 10

Del monitoreo pasamos a la gestión de vulnerabilidades y al parcheo.

Diagrama propio · plan de la parte: docs/analisis-tematico.md §2.4

EQUIPO

SOC y CSIRT: quién vigila y quién responde

Atención continua de un lado; respuesta coordinada del otro.

Centro de operaciones · vigila sin parar

Nivel 1 · triaje

abre la alerta, aplica las cuatro preguntas

y cierra lo que es benigno conocido

Nivel 2 · investigación

correlaciona eventos, arma la cronología

y decide si escala a incidente

Nivel 3 · caza

busca señales que nadie alertó

y escribe las reglas nuevas

Equipo de respuesta · actúa por caso

Coordinación

se nombra responsable, alcance y horario

antes de tocar el entorno

Contención y erradicación

se aísla, se retira el acceso y

se recupera desde respaldo

Comunicación y lecciones

se reporta a quien corresponda

y la causa vuelve como regla

escala cuando el impacto se confirma →

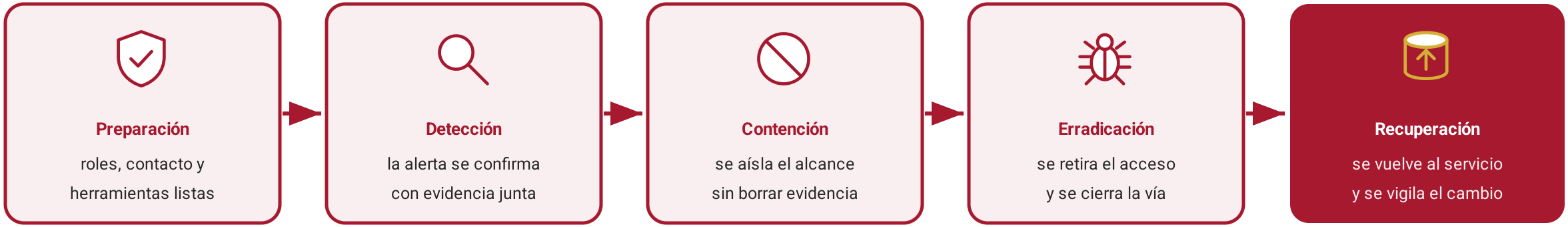
← reglas aprendidas vuelven al sensor

Concepto: operación de centros de monitoreo y respuesta; NIST SP 800-61 Rev.3 (2025)

PROCESO

El ciclo de respuesta, paso por paso

Preparación primero; después detección, contención, erradicación y recuperación.



Lecciones aprendidas: lo que se entendió vuelve a la preparación

Cada caso deja una regla nueva, una corrección de procedimiento o una brecha documentada.

El monitoreo que montamos en esta semana es la mitad de la detección; la otra mitad es el proceso.

Colombia: el marco y el circuito del reporte

Política nacional, equipo que responde y leyes que respaldan la bitácora.

El circuito del reporte

1 · La entidad reporta el incidente
con lo que vio y a qué hora lo vio

2 · Se clasifica la severidad
y se decide qué respuesta hace falta

3 · Se orienta la contención
con guías técnicas para la entidad

4 · Se difunde la alerta
para que otros corrijan el mismo hueco

Reportar temprano acorta la recuperación
de quien reporta y de los demás. Función estándar de un CSIRT nacional.

Política nacional

El CONPES 3995 de 2020, del DNP, puso metas y responsables a la seguridad digital.

Respuesta del Estado

El ColCERT, del MinTIC, recibe, clasifica y orienta los reportes de incidentes.

Obligaciones

Ley 1273 de 2009: delitos informáticos.

Ley 1581 de 2012: datos personales en bitácoras.

Registrar bien no es costumbre: es la base técnica y jurídica de la respuesta.

DNP, CONPES 3995 (2020) · Ley 1273 de 2009 · Ley 1581 de 2012 · función CSIRT: IETF RFC 2350 (1998)

CASO

IFX Networks, septiembre de 2023

Un proveedor en la nube, cientos de entidades afectadas y una respuesta nacional.

Cronología pública del incidente

12 sep

ataque con cifrado en el proveedor de nube

13–15 sep

762 compañías afectadas: la cifra de la semana, varios países

14–20 sep

la Rama Judicial suspende términos en todo el país

18 sep

la Fiscalía señala a RansomHouse como presunto autor

Lección 1 · dependencia

El incidente empezó en el proveedor y sus clientes no tenían visibilidad propia del servicio que usaban.

Lección 2 · continuidad

Sin respaldo probado y sin plan, la recuperación dependió del tiempo del tercero.

Lección 3 · registro

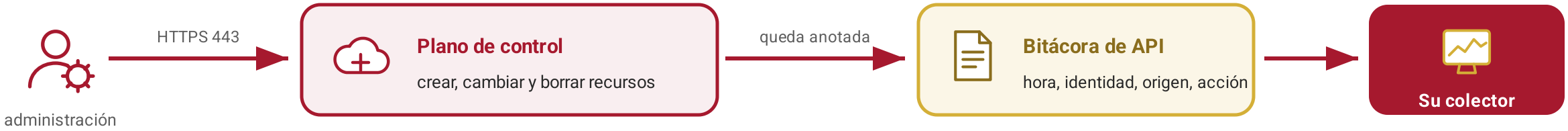
Las fechas que vimos arriba existen porque alguien guardó bitácoras y las publicó.

También se monitorea al tercero del que dependemos: pregunténle qué registro conserva.

EFE y prensa nacional (12–19 sep 2023) · Noticias RCN (18-sep-2023) · Rama Judicial: suspensión de términos 14–20 sep 2023

La nube se vigila en la bitácora de la API

Cada llamada de administración queda registrada: identidad, hora, origen y acción.



Las preguntas que esta bitácora responde

- ¿Quién creó o borró esa regla de acceso del firewall en la nube?
- ¿Desde qué dirección IP se administró el servicio y a qué hora exacta?
- ¿Qué permiso cambió justo antes de que apareciera el incidente?

El mismo concepto en cualquier proveedor

Ejemplos de bitácora de plano de control: CloudTrail de Amazon Web Services, Activity Log de Azure y Cloud Audit Logs de Google. El concepto es el registro de auditoría; el nombre es lo de menos.

La nube no externaliza la responsabilidad: la bitácora de la API es su evidencia.

Pregunte siempre cuánto retiene el proveedor y cómo se exporta hacia el colector de ustedes.

Diagrama propio · concepto: registro de auditoría de la API de control · NIST SP 800-92 (2006), §3.2

Del colector simple al SIEM libre: una opción de crecimiento

La misma arquitectura de siempre, con agente, motor de reglas y panel de consulta.



Qué añade sobre el colector con rsyslog

Índice de búsqueda
consultas en segundos sobre millones de eventos

Reglas listas
decodificadores y correlaciones mantenidas por la comunidad

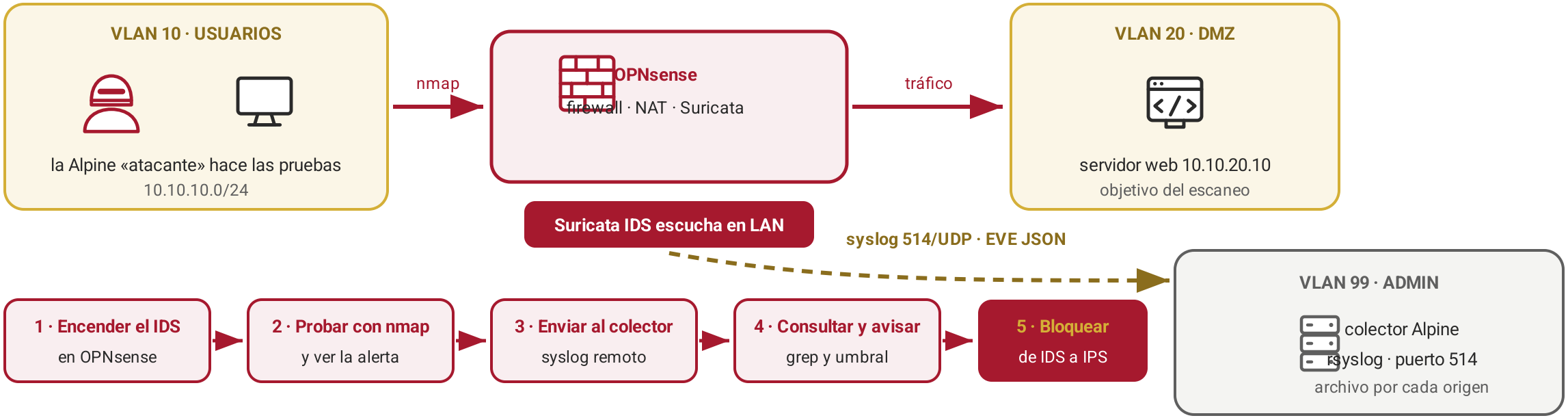
Paneles e informes
visualización sin escribir código

¿Cuándo hace falta? Volumen alto, correlación entre host y red, informes periódicos. En el laboratorio es opcional.

Concepto: arquitectura gestor-agente · Wazuh (wazuh.com) y Elastic (elastic.co), citados como ejemplo

La práctica: un sensor y un colector en su laboratorio

Sobre la topología del laboratorio: Suricata en OPNsense y rsyslog en Alpine.



Todo corre en VirtualBox: OPNsense, las Alpine del laboratorio y nada más. Cada paso tiene una verificación con un comando o con una pantalla antes de avanzar al siguiente.

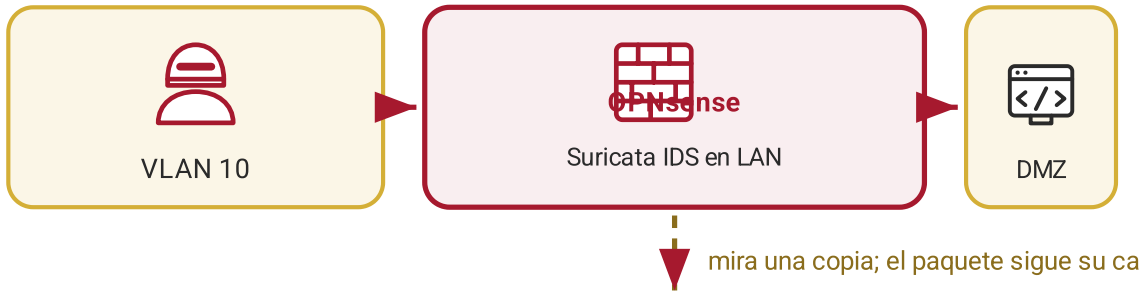
Diagrama propio · práctica sobre la plataforma del curso: VirtualBox + OPNsense + Alpine (Lab 1)

Paso 1 · Encender Suricata como IDS en OPNsense

Habilitar el servicio, descargar las reglas abiertas y verificar que escucha.

```
# 1 · en OPNsense, interfaz web
Services → Intrusion Detection → General
  Enable Suricata: sí
  Interfaces: LAN
  Capture mode: PCAP live move (IDS)
  Promiscuous mode: sí
# 2 · reglas del conjunto abierto
Services → Intrusion Detection → Download
  ET Open: marcar → descargar e instalar
# 3 · verificación del paso
Services → Intrusion Detection → Alerts
  el servicio corre, sin errores en el log
```

Modo IDS: el sensor observa una copia del tráfico; todavía no bloquea nada.



¿Por qué LAN y no WAN?

En la WAN, el NAT ya reescribió las direcciones:
la alerta no diría qué equipo interno generó el tráfico.

Punto de control

servicio corriendo, reglas instaladas y fecha reciente.

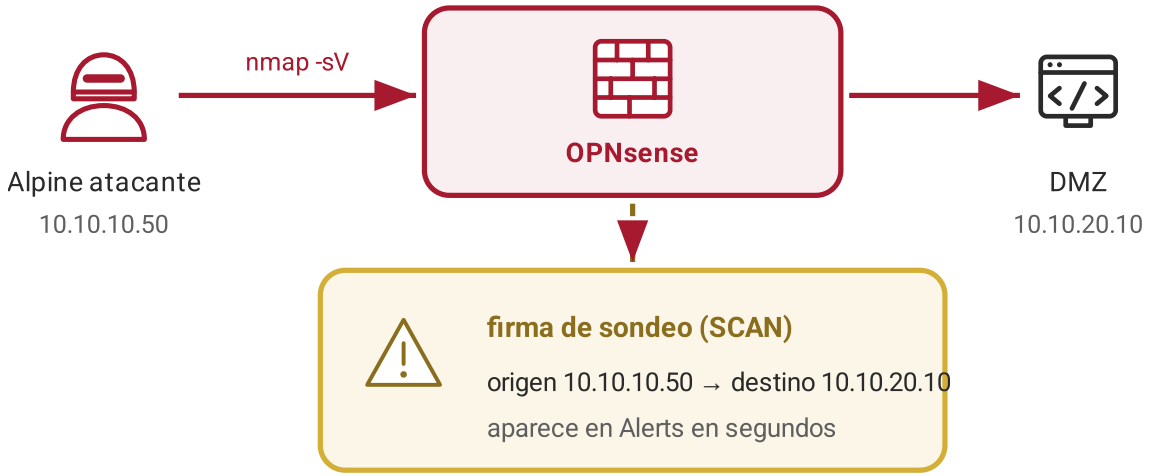
OPNsense, manual «Intrusion Prevention System» (docs.opnsense.org, consultado 4-oct-2026)

Paso 2 · Un escaneo de prueba y la primera alerta

Generar tráfico de sondeo controlado y verlo llegar al panel de alertas.

```
# desde la Alpine «atacante» · VLAN 10
apk add nmap
nmap -sV -p 22,80,443 10.10.20.10
# a los segundos, en OPNsense:
Services → Intrusion Detection → Alerts
#   buscar la familia de sondeo (SCAN)
#   origen: la IP de la Alpine atacante
#   hora: la misma del escaneo
```

Solo contra su laboratorio: el sondeo se hace dentro de la red propia, con permiso, hacia un equipo propio.



La hora de la alerta y la del escaneo coinciden
porque NTP quedó sincronizado en la Parte 1

La alerta ya es evidencia:
firma, código, origen, destino y hora, listos para correlacionar.

Paso 3 · Un colector remoto con rsyslog en Alpine

El sensor escribe; el colector recibe y guarda un archivo por cada origen.

```
# colector Alpine · VLAN 99
apk add rsyslog
mkdir -p /var/log/hosts
# /etc/rsyslog.conf — agregar:
module(load="imudp")
input(type="imudp" port="514" ruleset="remoto")
template(name="porhost" type="string"
  string="/var/log/hosts/%HOSTNAME%.log")
ruleset(name="remoto"){
  action(type="omfile" template="porhost")
  stop
}
rc-update add rsyslog boot
rc-service rsyslog start
# ¿escucha en el 514?
netstat -lun | grep 514
```

En OPNsense — dos ajustes

1 · IDS → General: activar la salida EVE por syslog.

2 · System → Settings → Logging → Targets: destino

nuevo: IP del colector, puerto 514, UDP, aplicación suricata.



/var/log/hosts/opnsense-lab.log

un archivo por cada origen que reporta

Verificar en este orden:

tcpdump -ni eth0 udp port 514 · luego: tail -f

Paso 4 · Consultar el colector y disparar el aviso

Contar por firma, comparar con un umbral y convertir el umbral en aviso.

```
# ¿llegan alertas del IDS?
grep '"event_type":"alert"' /var/log/hosts/opnsense*.log | tail -3
# ¿cuántas por firma?
grep -o '"signature":"[^"]*"' /var/log/hosts/opnsense*.log \
  | sort | uniq -c | sort -rn | head
# umbral del laboratorio (regla nuestra):
#   más de 20 sondeos en una hora desde la
#   misma IP de origen → aviso al correo del grupo
```

Correlación de bolsillo: condición, ventana y umbral, los tres ingredientes de la Parte 2, escritos en consola.



Diagrama propio · caso de uso del laboratorio: consultas grep(1)/uniq(1) sobre registros EVE JSON

Paso 5 · De IDS a IPS: descartar el paquete en el camino

Cambiar el modo de captura, pedir la acción de descarte y verificar el bloqueo.

```
# 1 · cambiar el modo de captura
Services → Intrusion Detection → General
  Capture mode: Netmap (IPS)
# 2 · reglas que descartan
Services → Intrusion Detection → Policies
  política nueva → acción: Drop
  (solo el conjunto de sondeo ET Open)
# 3 · consejos del fabricante
  Interfaces → Settings: sin offloading de hardware
  System → Tunables: dev.netmap.admode=2
#   (si VirtualBox no entrega paquetes al sensor)
# 4 · verificar
  repetir el nmap: el escaneo se corta
  en Alerts, la acción aparece como drop
```

Hasta aquí: IDS · el paquete llega



observa una copia, alerta, y el tráfico sigue

Ahora: IPS · el paquete no llega



en línea: descarta antes de entregar al servidor

Primero una semana en alert: un falso positivo en modo drop corta tráfico legítimo.

OPNsense, manual «Intrusion Prevention System» (docs.opnsense.org, 2026): modos Netmap, Policies y tunables

FUENTES

Referencias y lecturas de la semana

Normas y RFC primero; los manuales de las herramientas, a mano durante el laboratorio.

- IETF. (2009). *The Syslog Protocol* (RFC 5424); *TLS Transport Mapping for Syslog* (RFC 5425); *Transmission over UDP* (RFC 5426).
- IETF. (2012). *Transmission of syslog Messages over TCP* (RFC 6587).
- IETF. (2004). *Cisco Systems NetFlow Version 9* (RFC 3954); (2013). *IPFIX* (RFC 7011); (2010). *NTP v4* (RFC 5905); (1998). *Expectations for CSIRT* (RFC 2350).
- Kent, K. y Souppaya, M. (2006). *Guide to Computer Security Log Management* (NIST SP 800-92).
- Scarfone, K. y Grance, T. (2007). *Guide to Intrusion Detection and Prevention Systems* (NIST SP 800-94).
- NIST. (2025). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management* (SP 800-61 Rev. 3).
- MITRE. (2026). *ATT&CK Enterprise*: técnicas T1078, T1110, T1046, T1071, T1572, T1041. Consultado en octubre de 2026.
- Open Information Security Foundation. (2026). *Suricata User Guide* (suricata.io).
- The Zeek Project. (2026). *Zeek Documentation* (zeek.org).
- Deciso B. V. (2026). *OPNsense User Manual: Intrusion Prevention System; Log Files* (docs.opnsense.org).
- rsyslog. (2026). *rsyslog Documentation: imudp, templates, rulesets* (rsyslog.com).
- Departamento Nacional de Planeación. (2020). *Documento CONPES 3995: Política Nacional de Seguridad Digital*.
- Congreso de Colombia. (2009). *Ley 1273 de 2009*; (2012). *Ley 1581 de 2012*.
- EFE, El Tiempo y Noticias RCN. (12–19 de septiembre de 2023). Cobertura del incidente de IFX Networks.

Para el laboratorio: los manuales de OPNsense, Suricata, Zeek y rsyslog son la referencia de consulta; abranlos en pantalla mientras ejecutan los cinco pasos.

QUÉ SIGUE

De detectar a prevenir: qué viene ahora

La semana diez cambia la pregunta: de qué pasó a qué está expuesto.

Lo que se llevan de la semana 9

Evidencia
llega completa, a tiempo y con permiso para existir

SIEM
normaliza, correlaciona con ventana y umbral, prioriza

Sensor
firma y comportamiento, probado, medido y afinado

Práctica
de IDS a IPS, con colector remoto y aviso por umbral

Semana 9 · hoy
monitoreo, evidencia y detección
la red cuenta lo que pasa

→

Semana 10 · 12 oct
hardening y gestión de vulnerabilidades
descubrir · priorizar · parchear

→

Semana 11
repaso de la Unidad 2
ejercicios integradores

En la semana 10 la pregunta cambia

- De «¿qué pasó y cómo lo sé?» a «¿qué está expuesto y hasta cuándo?».
- Escaneo propio de hosts y servicios, priorización con severidad y explotación conocida.
- El mismo laboratorio: las Alpine y la DMZ que ya tienen montadas.

Monitorear cuenta por dónde entra el agua; la semana que viene es para tapar la gotera.

Diagrama propio · calendario oficial del curso · contenidos: docs/analisis-tematico.md §2.4